

INFORME PROFESIONAL

Política de Seguridad DLP

Prevención de Pérdida de Datos y aplicación del Principio del Menor Privilegio

Documento	Política de Seguridad DLP ampliada
Aplicación	Organizaciones que gestionan información confidencial, datos internos, documentos de clientes, registros financieros, legales o de recursos humanos.
Versión	1.0
Fecha	8 de julio de 2026
Preparado para	[Nombre de la organización]
Preparado por	[Responsable de Seguridad / TI]

Propósito del documento: establecer lineamientos claros para prevenir la fuga, pérdida, modificación o divulgación no autorizada de datos, combinando controles técnicos, procesos de revisión, capacitación del personal y una administración estricta de privilegios.

Documento de uso interno. Puede adaptarse a la realidad, tamaño, herramientas y normativa aplicable de cada organización.

Índice del informe

1. Introducción
2. Objetivos de la política DLP
3. Alcance, principios y marco de aplicación
4. Clasificación de datos
5. Control de acceso y Principio del Menor Privilegio
6. Monitoreo y auditoría
7. Prevención de filtraciones
8. Educación y concientización
9. Roles y responsabilidades
10. Respuesta a incidentes
11. Caso práctico: control de acceso en Google Drive
12. Indicadores, revisión y checklist de implementación
13. Conclusión

Este informe amplía cada campo de una política DLP básica para que pueda utilizarse como base de trabajo, entrega académica o borrador profesional dentro de una organización.

- Reducir la exposición de datos sensibles en canales como correo, nube, dispositivos removibles, impresiones y aplicaciones externas.
- Establecer controles de monitoreo que permitan detectar acciones anómalas o potencialmente riesgosas.
- Capacitar al personal para que reconozca información confidencial y sepa manejarla de forma segura.
- Asegurar el cumplimiento de obligaciones legales, regulatorias, contractuales y de buenas prácticas de seguridad.
- Documentar evidencias, revisiones y acciones correctivas para facilitar auditorías internas o externas.

2.3 Resultados esperados

Resultado	Descripción	Evidencia esperada
Menos permisos excesivos	Cada usuario mantiene únicamente los accesos necesarios para sus tareas vigentes.	Reportes trimestrales de revisión de accesos.
Mayor control de datos sensibles	Los documentos críticos tienen etiquetas, restricciones y reglas de uso.	Inventario de datos clasificados y reglas DLP activas.
Respuesta más rápida	Los eventos sospechosos generan alertas y procedimientos claros de actuación.	Registro de incidentes, tiempos de respuesta y cierre.
Personal más consciente	Los usuarios entienden qué datos protegen, por qué y cómo reportar riesgos.	Asistencia a capacitaciones y evaluaciones.

3. Alcance, principios y marco de aplicación

Esta política aplica a toda persona que acceda, almacene, procese, transfiera o administre información de la organización. Incluye empleados, directivos, proveedores, consultores, personal temporal, practicantes y terceros autorizados.

3.1 Alcance de la información protegida

- Documentos institucionales, contratos, informes, presupuestos, reportes financieros y archivos legales.
- Datos personales de clientes, usuarios, pacientes, empleados, postulantes o proveedores.
- Credenciales, configuraciones técnicas, respaldos, código, documentación de infraestructura y registros de sistemas.
- Información comercial, listas de clientes, estrategias, datos de ventas, campañas y acuerdos de confidencialidad.
- Toda información marcada como interna, confidencial o sensible, sin importar si está en formato digital o físico.

3.2 Principios rectores

Principio	Aplicación práctica
Menor privilegio	Cada usuario recibe solo los permisos mínimos necesarios para realizar su trabajo, durante el tiempo necesario.
Necesidad de saber	La pertenencia a la organización no habilita acceso automático a información no relacionada con el cargo.
Trazabilidad	Toda acción relevante sobre datos sensibles debe poder atribuirse a un usuario, fecha, dispositivo y acción concreta.

Principio	Aplicación práctica
Responsabilidad compartida	La seguridad no depende solo del área de TI. Cada usuario debe proteger los datos a los que accede.
Revisión continua	Los permisos, reglas, herramientas y capacitaciones deben actualizarse según cambios de personal, procesos y amenazas.
Regla de interpretación: cuando exista duda sobre si una información debe compartirse, descargarse o enviarse, se aplicará el criterio más restrictivo hasta obtener autorización formal.	

4. Clasificación de datos

La clasificación de datos permite identificar el nivel de protección requerido para cada tipo de información. Sin clasificación, la organización tiende a proteger todo de forma insuficiente o a restringir en exceso información que no lo requiere. La clasificación debe estar visible para los usuarios y vinculada a reglas de acceso, retención, cifrado y monitoreo.

Categoría	Definición	Ejemplos	Controles mínimos
Pública	Información aprobada para difusión externa o de bajo impacto si se comparte.	Sitio web, folletos, comunicados públicos, material comercial aprobado.	Revisión previa de comunicación; control de versiones; aprobación de publicación.
Interna	Información de uso habitual dentro de la organización, no destinada al público general.	Procedimientos internos, manuales, organigramas, calendarios, documentos operativos.	Acceso solo a personal activo; no publicar externamente; compartir mediante canales corporativos.
Confidencial	Información cuyo acceso indebido puede generar perjuicio operativo, económico o reputacional.	Contratos, informes de gestión, datos de clientes, estrategias comerciales, evaluaciones internas.	Acceso por rol; MFA; registro de actividad; bloqueo de enlaces públicos; revisión trimestral.
Sensible	Información crítica o regulada que requiere el máximo nivel de protección.	Datos financieros, legales, RRHH, salud, credenciales, incidentes, información personal crítica.	Acceso muy restringido; cifrado; alertas; aprobación formal; prohibición de descarga salvo excepción.

4.1 Criterios para clasificar

- Impacto potencial si la información se filtra, pierde, altera o destruye.
- Obligaciones legales, regulatorias o contractuales asociadas a esos datos.
- Cantidad de personas afectadas por una exposición indebida.
- Valor comercial, estratégico o reputacional de la información.
- Necesidad de colaboración y nivel de exposición requerido para operar.

4.2 Reglas operativas de clasificación

- 1 Todo nuevo repositorio, carpeta compartida o base de datos debe contar con un responsable y una clasificación inicial.
- 2 Los documentos confidenciales o sensibles deben etiquetarse de forma visible, por ejemplo: 'Confidencial', 'Uso interno' o 'Sensible'.
- 3 La clasificación debe revisarse cuando cambie el contenido, el proyecto, el equipo responsable o el nivel de riesgo.
Los datos sensibles no deben copiarse a ubicaciones no autorizadas para facilitar el trabajo cotidiano.
- 4

- 5 Cuando se integren proveedores externos, el contrato debe indicar qué datos pueden tratar y bajo qué restricciones.

5. Control de acceso y Principio del Menor Privilegio

El Principio del Menor Privilegio establece que cada usuario, sistema o servicio debe tener únicamente los permisos estrictamente necesarios para cumplir una función concreta. Este principio reduce el daño potencial ante errores humanos, cuentas comprometidas, accesos heredados o uso indebido de privilegios.

5.1 Modelo de acceso

Control	Descripción ampliada	Responsable
RBAC	El acceso se asignará por roles y no por decisiones individuales aisladas. Cada rol tendrá permisos predefinidos según tareas reales.	TI / Seguridad / Dueños de proceso
MFA	La autenticación multifactor será obligatoria para accesos a correo, nube, VPN, herramientas administrativas y repositorios sensibles.	TI
Alta de usuarios	Toda cuenta nueva deberá estar asociada a una solicitud formal, rol, responsable, fecha de alta y justificación de permisos.	RRHH / TI / Responsable del área
Cambio de funciones	Si una persona cambia de cargo, sus accesos anteriores deben revisarse antes de otorgar los nuevos, evitando acumulación de privilegios.	RRHH / Jefatura / TI
Baja de usuarios	Al finalizar la relación laboral o contractual, las cuentas deben deshabilitarse de inmediato y los permisos compartidos revocarse.	RRHH / TI
Acceso temporal	Los accesos excepcionales deben tener fecha de vencimiento, motivo, aprobador y registro de acciones realizadas.	Seguridad / Responsable del dato

5.2 Revisión de permisos

La revisión periódica es fundamental porque los permisos tienden a acumularse con el tiempo. Las revisiones deben identificar usuarios inactivos, carpetas con permisos amplios, grupos mal configurados, enlaces públicos, permisos de edición innecesarios y accesos de terceros que ya no participan en el proceso.

- Periodicidad mínima: trimestral para información confidencial o sensible; semestral para información interna.
- Participantes: responsable del dato, área de TI, seguridad de la información y jefaturas correspondientes.
- Criterio: todo permiso sin justificación vigente debe ser revocado o reducido.
- Evidencia: acta o reporte con fecha, responsables, cambios aplicados y accesos pendientes de regularización.

5.3 Matriz de permisos recomendada

Nivel de dato	Lectura	Edición	Descarga	Compartir externamente
Pública	Permitida a personal autorizado	Equipo responsable	Permitida según necesidad	Permitido con aprobación de comunicación
Interna	Personal activo	Responsables del proceso	Solo dispositivos corporativos	No permitido salvo autorización

Nivel de dato	Lectura	Edición	Descarga	Compartir externamente
Confidencial	Solo roles definidos	Muy limitado	Restringida y registrada	Solo con aprobación formal
Sensible	Usuarios nominados	Excepcional	Bloqueada por defecto	Prohibido salvo excepción documentada

6. Monitoreo y auditoría

El monitoreo permite detectar comportamientos anómalos, intentos de exfiltración, accesos indebidos, configuraciones inseguras o incumplimientos de la política. La auditoría, por su parte, permite comprobar si los controles funcionan y si las decisiones tomadas quedan documentadas.

6.1 Eventos que deben registrarse

- Inicio de sesión exitoso o fallido, especialmente desde ubicaciones, horarios o dispositivos inusuales.
- Acceso, descarga, edición, eliminación, copia o transferencia de documentos confidenciales o sensibles.
- Creación de enlaces públicos, cambios de permisos y compartición con usuarios externos.
- Carga masiva de archivos a servicios no aprobados o descarga inusual de grandes volúmenes de información.
- Uso de dispositivos USB, impresión de documentos sensibles o envío de adjuntos críticos por correo.
- Cambios en reglas DLP, grupos de seguridad, roles administrativos o configuraciones de auditoría.
-

6.2 Herramientas y mecanismos

Herramienta / mecanismo	Uso recomendado
DLP corporativo	Aplicar reglas automáticas para detectar datos sensibles, bloquear acciones o advertir al usuario antes de compartir.
SIEM	Centralizar logs de diferentes sistemas, correlacionar eventos y generar alertas de seguridad.
CASB / controles de nube	Supervisar uso de aplicaciones SaaS, almacenamiento en nube y compartición externa.
EDR / Endpoint	Detectar actividad sospechosa en equipos, copia de datos, malware o comportamiento anómalo.
Auditorías manuales	Revisar carpetas críticas, permisos, usuarios externos, grupos y excepciones vigentes.

6.3 Alertas prioritarias

Alerta	Condición	Acción inicial
Enlace publico en dato sensible	Se habilita 'cualquier persona con el enlace' en documento sensible.	Bloquear enlace, notificar al responsable y registrar incidente.
Descarga masiva	Un usuario descarga volumen inusual de archivos en poco tiempo.	Validar justificación, revisar cuenta y preservar evidencias.
Externo no autorizado	Se comparte carpeta confidencial con dominio externo no aprobado.	Revocar acceso y solicitar autorización documentada.

Alerta	Condición	Acción inicial
Fallo repetido de inicio de sesión	Múltiples intentos fallidos en cuenta con acceso privilegiado.	Forzar cambio de contraseña, revisar MFA y bloquear si corresponde.

7. Prevención de filtraciones

La prevención de filtraciones combina medidas técnicas, administrativas y de comportamiento. Ningún control aislado es suficiente: bloquear USB no evita un enlace mal compartido; cifrar archivos no corrige permisos excesivos; capacitar usuarios no reemplaza el monitoreo.

7.1 Controles técnicos

Canal de riesgo	Medida preventiva	Criterio de aplicación
Dispositivos USB	Bloqueo por defecto o autorización por lista blanca.	Solo personal con necesidad operativa justificada y registro de uso.
Correo electrónico	Reglas DLP para detectar adjuntos sensibles, destinatarios externos y datos personales.	Advertir, bloquear o solicitar aprobación según criticidad.
Nube colaborativa	Deshabilitar enlaces públicos, limitar dominios externos y controlar permisos de descarga.	Aplicar especialmente a carpetas confidenciales y sensibles.
Impresión	Restricción de impresión, impresión segura con autenticación y registro.	Obligatorio para datos sensibles y RRHH.
Equipos finales	Cifrado de disco, bloqueo de pantalla, EDR y actualizaciones obligatorias.	Todos los equipos corporativos y portátiles.
Transferencia de archivos	Uso de canales corporativos cifrados y prohibición de servicios personales no aprobados.	Archivos confidenciales o sensibles.

7.2 Cifrado y protección de datos

- Cifrado en tránsito: toda transferencia de información debe realizarse mediante protocolos seguros y canales autorizados.
- Cifrado en reposo: equipos portátiles, bases de datos, respaldos y repositorios críticos deben mantenerse cifrados.
- Gestión de claves: las claves de cifrado deben administrarse de forma centralizada, con acceso restringido y rotación definida.
- Protección de respaldos: los backups deben cifrarse, probarse periódicamente y almacenarse con permisos limitados.
- Separación de ambientes: datos reales sensibles no deben utilizarse en ambientes de prueba sin anonimización o autorización formal.

7.3 Reglas DLP sugeridas

- 1 Bloquear el envío externo de documentos marcados como 'Sensible', salvo autorización explícita.
- 2 Advertir al usuario cuando intente enviar información confidencial a un dominio externo.
- 3 Impedir la descarga de archivos sensibles desde dispositivos no administrados.
- 4 Detectar patrones de datos personales, financieros, legales o de RRHH en adjuntos y repositorios.
- 5 Registrar y revisar todo intento de compartir carpetas críticas con usuarios externos.
- 6 Aplicar cuarentena o bloqueo automático cuando se detecte exfiltración masiva.

8. Educación y concientización

La tecnología DLP puede bloquear muchas acciones, pero la seguridad depende en gran parte del comportamiento humano. La capacitación debe explicar qué información se protege, cuáles son los riesgos reales y qué acciones cotidianas pueden provocar una fuga de datos.

8.1 Plan de capacitación

Actividad	Frecuencia	Contenido
Inducción de seguridad	Al ingreso	Clasificación de datos, uso aceptable, contraseñas, MFA, canales autorizados y reporte de incidentes.
Curso DLP obligatorio	Semestral	Casos de fuga de información, manejo de datos sensibles, correo seguro, nube y dispositivos externos.
Simulaciones de phishing	Trimestral	Evaluar reacción ante correos sospechosos y reforzar buenas prácticas.
Microcampañas	Mensual	Recordatorios breves sobre enlaces públicos, adjuntos, datos personales y privilegios mínimos.
Evaluación de conocimientos	Semestral	Preguntas prácticas y confirmación de lectura de la política.

8.2 Mensajes clave para los usuarios

- No compartas documentos confidenciales con enlaces públicos o cuentas personales.
- Antes de enviar un archivo, revisa destinatario, adjunto, clasificación y permisos.
- No descargues datos sensibles en dispositivos no autorizados.
- Reporta de inmediato errores de envío, accesos sospechosos o pérdida de dispositivos.
- No acumules permisos: si ya no necesitas acceso a una carpeta, solicita su remoción.
- La seguridad de la información es parte de tu función, no una tarea exclusiva del área de TI.

Recomendación: usar ejemplos concretos de la organización aumenta la comprensión. Por ejemplo, mostrar cómo un enlace abierto de Google Drive puede exponer contratos, datos de clientes o documentos de RRHH.

9. Roles y responsabilidades

Una política DLP necesita responsables claros. Si no se define quién aprueba, implementa, revisa, monitorea y reporta, los controles quedan en buenas intenciones pero no se sostienen en el tiempo.

Rol	Responsabilidades principales
Dirección	Aprobar la política, asignar recursos, respaldar acciones correctivas y exigir cumplimiento a todas las áreas.
Responsable de Seguridad	Diseñar controles, evaluar riesgos, coordinar monitoreo, investigar incidentes y reportar resultados.
Área de TI	Configurar herramientas, usuarios, permisos, MFA, cifrado, backups, logs y reglas técnicas DLP.
Responsables de área	Validar quién necesita acceso a la información del área y revisar permisos periódicamente.
Dueños de datos	Definir clasificación, condiciones de uso, restricciones y autorizaciones excepcionales.
RRHH	Informar altas, bajas y cambios de funciones; incluir seguridad en inducción y desvinculación.

Rol	Responsabilidades principales
Usuarios	Cumplir la política, proteger credenciales, usar canales autorizados y reportar anomalías.
Proveedores	Acceder solo a datos autorizados, cumplir acuerdos de confidencialidad y aceptar controles de seguridad.

9.1 Flujo de aprobación de accesos

- 1 El usuario responsable solicita acceso indicando carpeta, sistema, motivo, nivel requerido y tiempo estimado.
- 2 El dueño del dato valida si existe necesidad real y si el nivel de permiso solicitado es adecuado.
- 3 TI o Seguridad implementa el acceso usando grupos o roles definidos, no permisos individuales innecesarios.
- 4 El acceso queda registrado con solicitante, aprobador, fecha y vencimiento si corresponde.
- 5 Durante la revisión periódica se confirma si el acceso sigue siendo necesario o debe revocarse.

10. Respuesta a incidentes

La política debe indicar cómo actuar cuando se detecta o sospecha una fuga de datos. La rapidez es importante, pero también lo es preservar evidencias y evitar acciones improvisadas que dificulten la investigación.

Fase	Acciones
1. Identificación	Detectar el evento mediante alerta, reporte de usuario, auditoría o monitoreo. Registrar fecha, sistema, usuario, datos afectados y canal de exposición.
2. Contención	Revocar accesos, bloquear enlaces, aislar equipos, detener transferencias y preservar logs sin borrar evidencias.
3. Análisis	Determinar causa raíz, alcance, tipo de datos involucrados, usuarios afectados y si hubo acceso externo o descarga.
4. Erradicación	Corregir permisos, cerrar vulnerabilidades, eliminar configuraciones inseguras y reforzar controles DLP.
5. Recuperación	Restaurar operación normal, validar que los controles funcionan y comunicar a las áreas correspondientes.
6. Lecciones aprendidas	Documentar hallazgos, actualizar políticas, capacitar nuevamente y mejorar indicadores de detección y respuesta.

10.1 Criterios de severidad

Nivel	Descripción	Ejemplo
Bajo	Evento sin exposición externa y con datos internos de bajo impacto.	Permiso de lectura otorgado por error a un área interna.
Medio	Exposición limitada de información confidencial sin evidencia de descarga masiva.	Archivo contractual compartido con usuario interno no autorizado.
Alto	Datos sensibles compartidos externamente, descarga masiva o cuenta comprometida.	Carpeta de RRHH enviada a dominio externo no aprobado.
Crítico	Exposición significativa, impacto legal, regulatorio, reputacional o afectación masiva.	Base de clientes filtrada o publicada en internet.

Registro mínimo del incidente: fecha, hora, usuario, sistema, datos afectados, canal, clasificación, acciones de contención, responsables, evidencia preservada, decisión de comunicación y cierre.

11. Caso práctico: control de acceso en Google Drive

Como ejemplo de aplicación, se considera un entorno donde la organización utiliza Google Drive para almacenar, compartir y colaborar en documentos laborales. El riesgo principal es que carpetas o archivos sensibles queden expuestos por permisos excesivos, enlaces públicos o usuarios externos que ya no deberían conservar acceso.

11.1 Política aplicada al caso

- Las carpetas se organizarán por áreas y nivel de clasificación: pública, interna, confidencial y sensible.
- Los documentos sensibles no podrán compartirse con 'cualquier persona con el enlace'. Esta opción debe permanecer deshabilitada por defecto.
- La edición se limitará al equipo responsable. Otros usuarios podrán tener solo lectura si su función lo justifica.
- El acceso externo requerirá aprobación del dueño del dato y fecha de vencimiento definida.
- Las carpetas críticas tendrán revisión trimestral de permisos, usuarios externos y enlaces activos.
- Se activarán alertas ante compartición externa, descarga masiva, cambios de permisos y creación de enlaces públicos.

11.2 Ejemplo de flujo

- 1 El área Legal crea una carpeta 'Contratos 2026' clasificada como Confidencial.
- 2 Solo integrantes del área Legal tienen permisos de edición. Dirección puede tener lectura. Otros usuarios no tienen acceso.
- 3 Un proveedor externo necesita revisar un contrato por 10 días. Legal solicita autorización temporal.
- 4 TI otorga acceso de lectura al proveedor, sin descarga si la herramienta lo permite, y registra fecha de vencimiento.
- 5 Finalizado el plazo, el acceso externo se revoca automáticamente o mediante revisión manual documentada.
- 6 Durante la auditoría trimestral se verifica que no existan enlaces públicos ni usuarios externos activos sin justificación.

Riesgo en Google Drive	Control recomendado
Enlace público creado por error	Bloquear enlaces públicos para datos confidenciales y sensibles; generar alerta automática.
Permiso de edición innecesario	Usar lectura por defecto y edición solo para responsables directos.
Usuario externo olvidado	Permisos temporales con vencimiento y revisión trimestral.
Descarga masiva	Alertas de actividad anómala y restricción de descarga en documentos sensibles.
Carpetas compartidas con grupos amplios	Revisión de grupos y aplicación estricta de necesidad de saber.

12. Indicadores, revisión y checklist de implementación

Para que la política DLP se sostenga, deben definirse indicadores de seguimiento. Los indicadores permiten demostrar avances, detectar áreas débiles y priorizar acciones correctivas.

12.1 Indicadores sugeridos

Indicador	Qué mide	Frecuencia
Permisos excesivos corregidos	Cantidad de accesos revocados o reducidos durante revisiones.	Trimestral
Eventos DLP bloqueados	Intentos de compartir, descargar o enviar datos sensibles bloqueados por reglas.	Mensual
Enlaces públicos detectados	Archivos o carpetas con exposición pública no autorizada.	Mensual
Usuarios externos activos	Terceros con acceso vigente a repositorios internos o sensibles.	Mensual
Tiempo de contención	Tiempo entre detección del incidente y primera acción de contención.	Por incidente
Capacitación completada	Porcentaje de usuarios que completaron formación y evaluación.	Semestral

12.2 Revisión de la política

La política debe revisarse al menos una vez al año o antes si ocurre un incidente relevante, cambio normativo, incorporación de nuevas herramientas, migración a nuevos sistemas, reestructura interna o auditoría con hallazgos significativos.

12.3 Checklist de implementación

Estado	Actividad
[]	Definir dueño de la política DLP y responsables por área.
[]	Inventariar repositorios, sistemas y carpetas que contienen datos internos, confidenciales o sensibles.
[]	Establecer categorías de clasificación y ejemplos concretos para la organización.
[]	Configurar MFA en servicios críticos y cuentas con privilegios.
[]	Crear roles de acceso y eliminar permisos individuales innecesarios.
[]	Deshabilitar enlaces públicos por defecto en datos confidenciales y sensibles.
[]	Implementar reglas DLP para correo, nube, endpoints y dispositivos removibles.
[]	Centralizar logs y configurar alertas prioritarias.
[]	Realizar primera revisión trimestral de permisos.
[]	Capacitar al personal y registrar asistencia.
[]	Documentar procedimiento de respuesta a incidentes.
[]	Definir indicadores mensuales y responsables de seguimiento.

13. Conclusión

Una estrategia de Prevención de Pérdida de Datos bien diseñada permite proteger información crítica, reducir errores humanos, limitar el impacto de cuentas comprometidas y mejorar la capacidad de respuesta ante incidentes. Sin embargo, su éxito depende de una aplicación constante: clasificar datos, limitar permisos, revisar accesos, monitorear eventos, capacitar a las personas y actuar rápidamente ante cualquier exposición indebida.

El Principio del Menor Privilegio debe considerarse una práctica permanente y no una configuración inicial. Cada cambio de personal, proyecto, proveedor, herramienta o proceso puede modificar los riesgos y requiere revisar quién tiene acceso, a qué información, con qué nivel de permiso y por cuánto tiempo.

Al implementar esta política, la organización fortalece su cultura de seguridad, mejora su trazabilidad, reduce la superficie de exposición y demuestra un compromiso activo con la protección de sus datos, clientes, empleados y activos estratégicos.

Resumen ejecutivo: DLP + menor privilegio = menos exposición, mejor control, más trazabilidad y una respuesta más ordenada frente a incidentes de seguridad.